

Public Cloud Services Security





Wie war die Arbeitslast?



Wie war das benötigte Vorwissen?



Was bringt das Modul an Mehrwert (ausser ECTS)?



Was hat gefehlt/zu wenig an Thematiken?



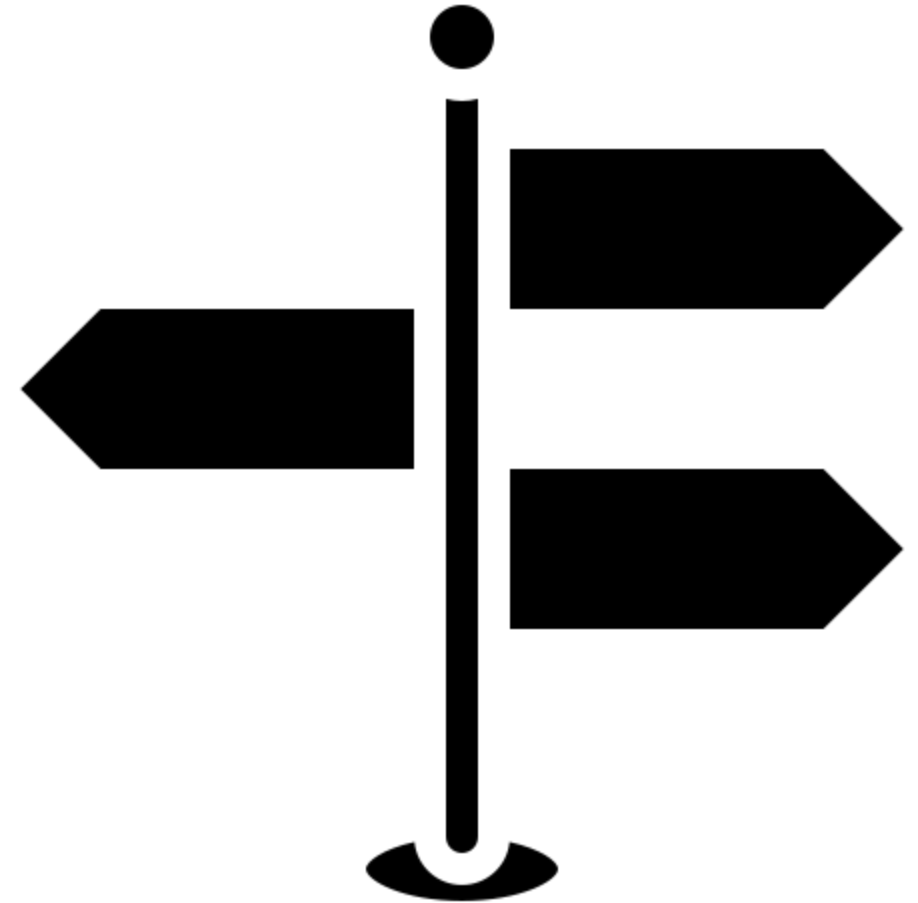
Welcher Inhalt war obsolet/zu viel?



Was sollte beibehalten werden?

Learning Objectives

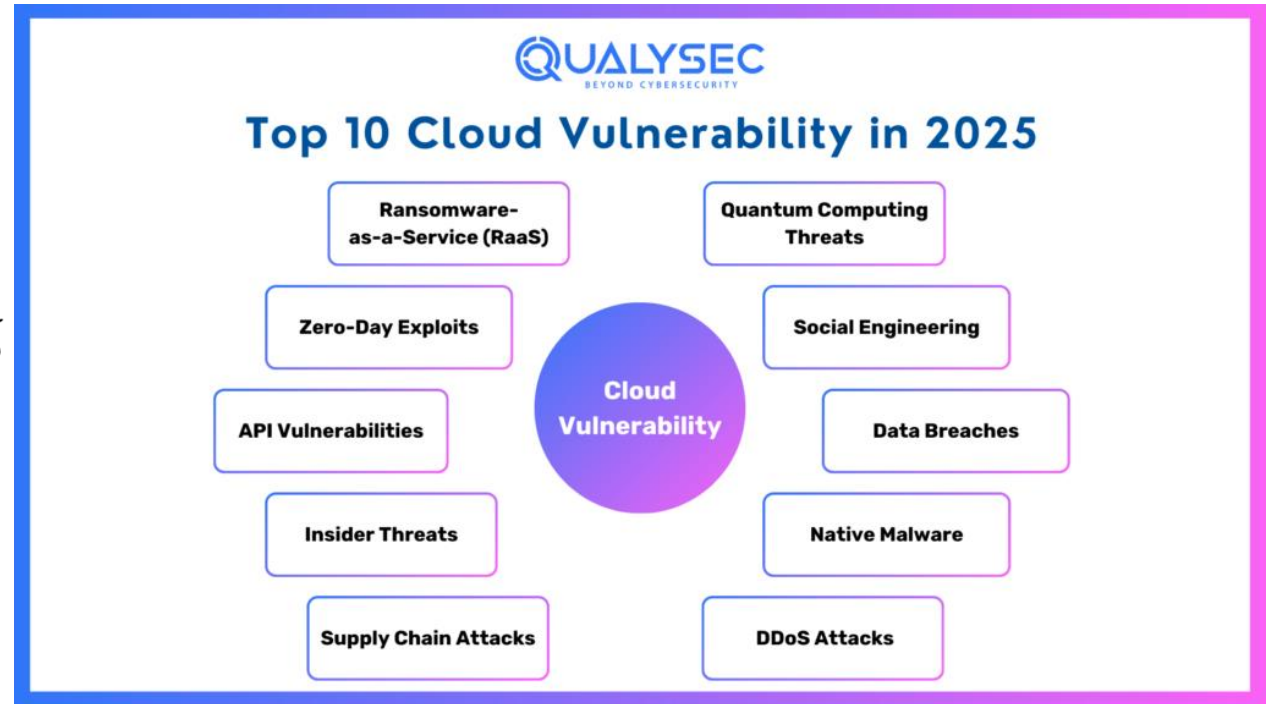
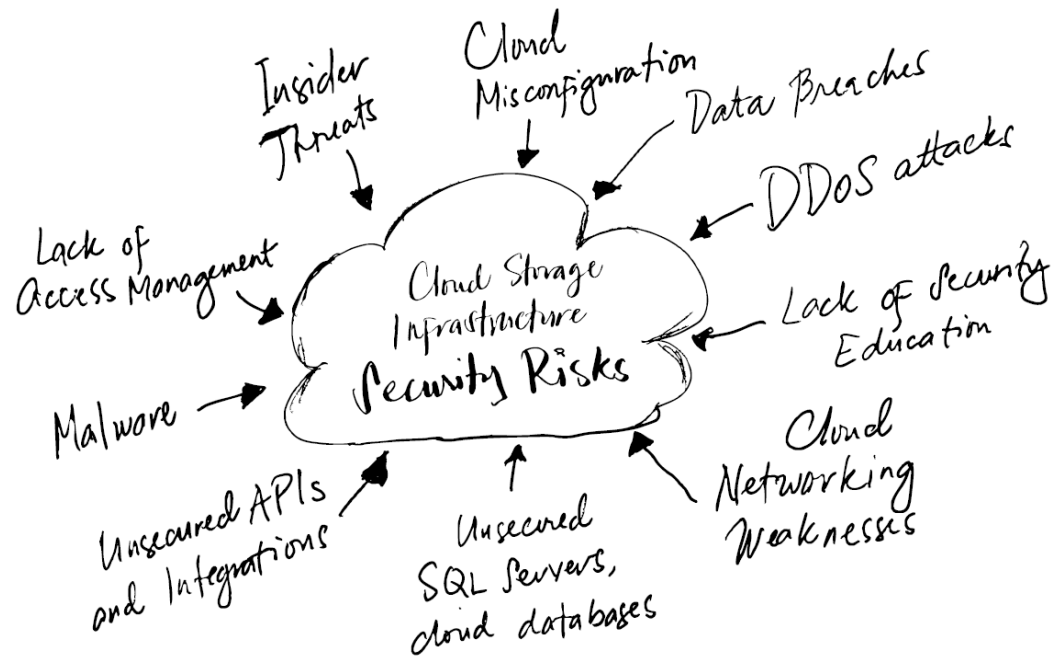
- Students understand the difference between management and data plane security.
- Students can explain and apply common security concepts such as authentication, authorization, RBAC, etc.
- Students are familiar with services for securing applications in the cloud



Motivation



Dangers



Foundational concepts

Controlplane und Dataplanesecurity

- Or also “security of the cloud” and “security in the cloud”
- Control plane: Securing the cloud, e.g., via access permissions
- Data plane: Securing the cloud resources used, e.g., via network rules
- Both areas can use similar controls such as RBAC, network rules, WAF, etc.

<https://aws.amazon.com/compliance/shared-responsibility-model/>

AWS responsibility “Security of the Cloud”

AWS is responsible for protecting the infrastructure that runs all of the services offered in the AWS Cloud. This infrastructure is composed of the hardware, software, networking, and facilities that run AWS Cloud services.

Customer responsibility “Security in the Cloud”

Customer responsibility will be determined by the AWS Cloud services that a customer selects. This determines the amount of configuration work the customer must perform as part of their security responsibilities. For example, a service such as Amazon Elastic Compute Cloud (Amazon EC2) is categorized as Infrastructure as a Service (IaaS) and, as such, requires the customer to perform all of the necessary security configuration and management tasks. Customers that deploy an Amazon EC2 instance are responsible for management of the guest operating system (including updates and security patches), any application software or utilities installed by the customer on the instances, and the configuration of the AWS-provided firewall (called a security group) on each instance. For abstracted services, such as Amazon S3 and Amazon DynamoDB, AWS operates the infrastructure layer, the operating system, and platforms, and customers access the endpoints to store and retrieve data. Customers are responsible for managing their data (including encryption options), classifying their assets, and using IAM tools to apply the appropriate permissions.

This customer/AWS shared responsibility model also extends to IT controls. Just as the responsibility to operate the IT environment is shared between AWS and its customers, so is the management, operation and verification of IT controls shared. AWS can help relieve customer burden of operating controls by managing those controls associated with the physical infrastructure deployed in the AWS environment that may previously have been managed by the customer. As every customer is deployed differently in AWS, customers can take advantage of shifting management of certain IT controls to AWS which results in a (new) distributed control environment. Customers can then use the AWS control and compliance documentation available to them to perform their control evaluation and verification procedures as required. Below are examples of controls that are managed by AWS, AWS Customers and/or both.

Controlplane

- Cloud control level – for all cloud consumers for their own cloud resources
- REST API-based
- Managed by the cloud provider
- Additional security measures available for the customer

To discover which operations use the Azure Resource Manager URL, see the [Azure REST API](#). For example, the [create or update operation](#) for MySQL is a control plane operation because the request URL is:

HTTP

 Copy

PUT <https://management.azure.com/subscriptions/{subscriptionId}/resourceGroups/{re>

<https://learn.microsoft.com/en-us/azure/azure-resource-manager/management/control-plane-and-data-plane>

<https://docs.aws.amazon.com/whitepapers/latest/aws-fault-isolation-boundaries/control-planes-and-data-planes.html>

Dataplane

- Endpoints of cloud resources created via the control plane
- Operated by cloud providers, secured by customers
- Technology-agnostic (REST API, TCP endpoint, etc.)
- Authorization structures can be analogous to the control plane (e.g., Azure RBAC) but do not have to be

Requests for data plane operations are sent to an endpoint that's specific to your instance. For example, the [Detect Language operation](#) in Azure AI services is a data plane operation because the request URL is:

HTTP

 Copy

POST {Endpoint}/text/analytics/v2.0/languages

Data plane operations aren't limited to REST API. They might require other credentials, such as logging in to a virtual machine or database server.

Security principles in the cloud

Principle of least privilege

Only grant permissions that are necessary for the task

Assume breach

Expect security mechanisms to be undermined

Zero Trust

A strategy (and combination) of assume breach and principle of least privilege with explicit verification of access

Just-in-time access

Access is granted for a time window and revoked afterwards

Secure baseline

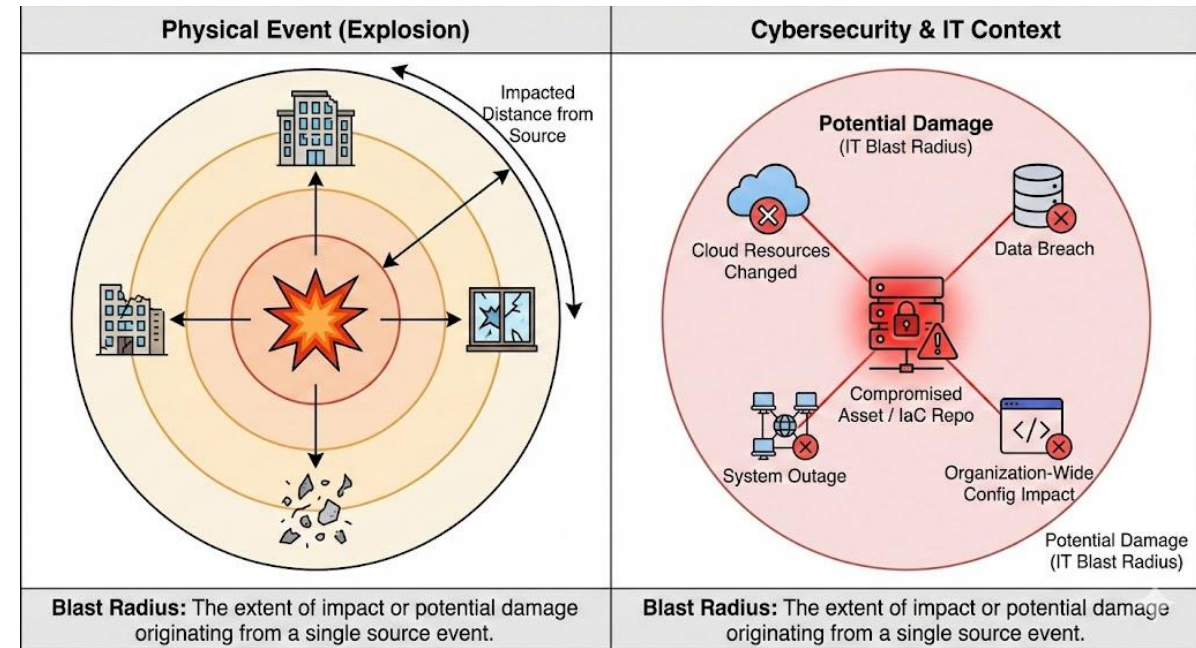
Follow hardening & configuration best practices from cloud provider for provisioned cloud services

Defense in depth

Use multiple layers security mechanisms

Blast Radius

- Originates from a physical, explosive event
- Defines the distance from the source that is impacted
- Mapped to cybersecurity and IT-assets
- E.g. the potential damage if an asset is compromised
- May also be applied to non-security areas, like an IaC repo (and its potential to change resources across the whole organization)



Generated through Nano Banana Pro

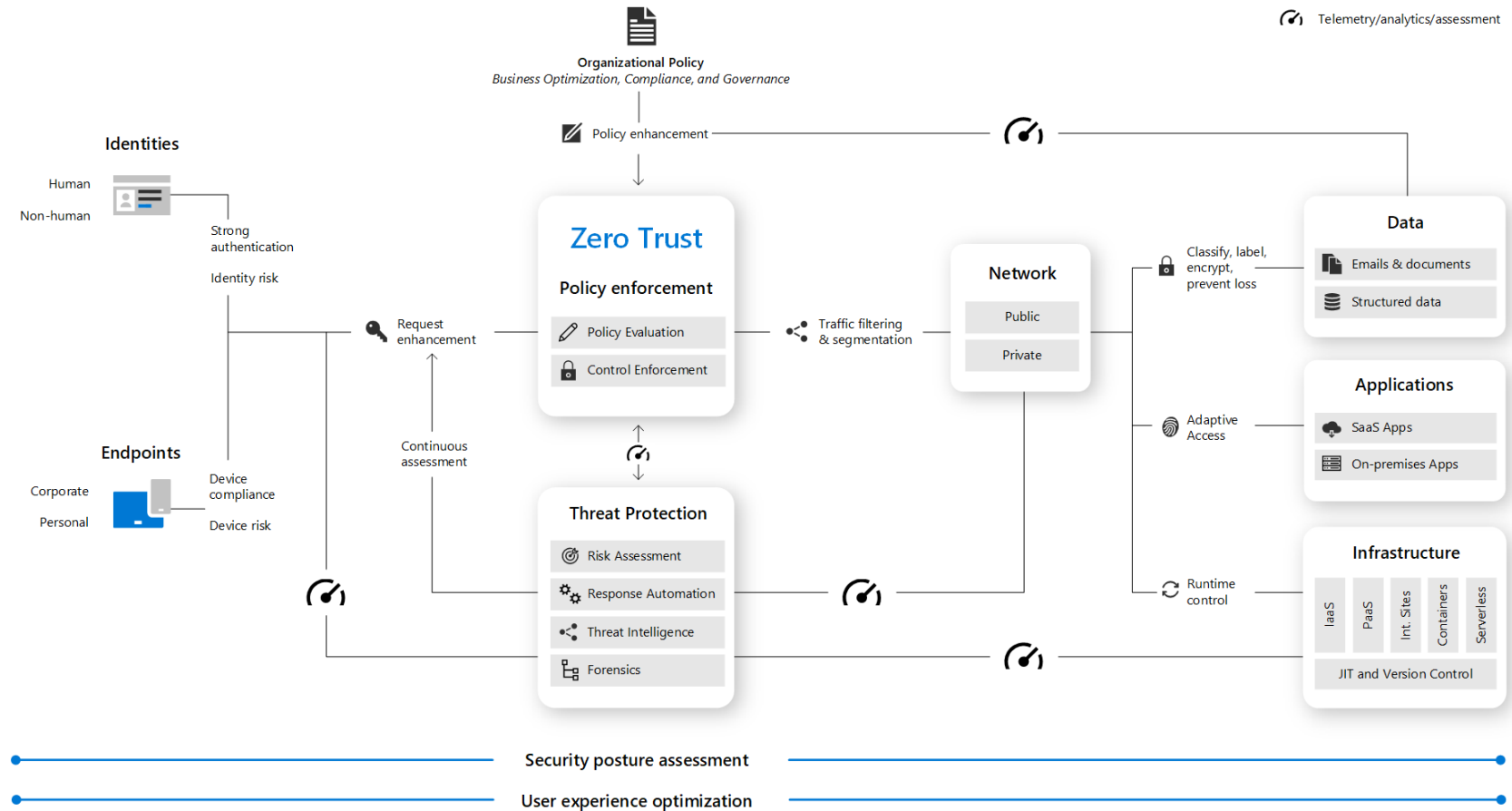
<https://techcommunity.microsoft.com/blog/microsoft-security-blog/microsoft-security-exposure-management-graph-prioritization-is-the-king/4160316>

Zero Trust

Principles

- Verify each access explicitly with an identity (not only a network source or destination)
- Assume a security mechanism will fail (monitor and plan ahead)

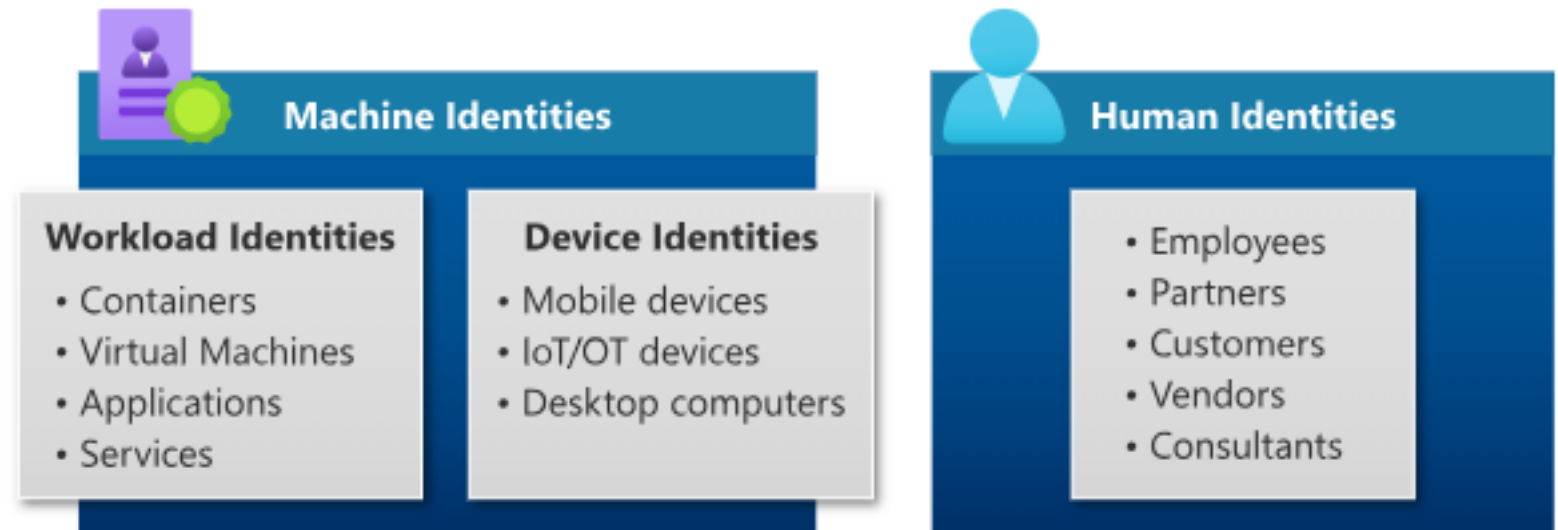
Zero Trust is a journey!



<https://learn.microsoft.com/en-us/azure/security/fundamentals/zero-trust>

Identities

- Representation of people and machines
- Both are represented in the cloud by means of identities, e.g., in the form of accounts or security principals.



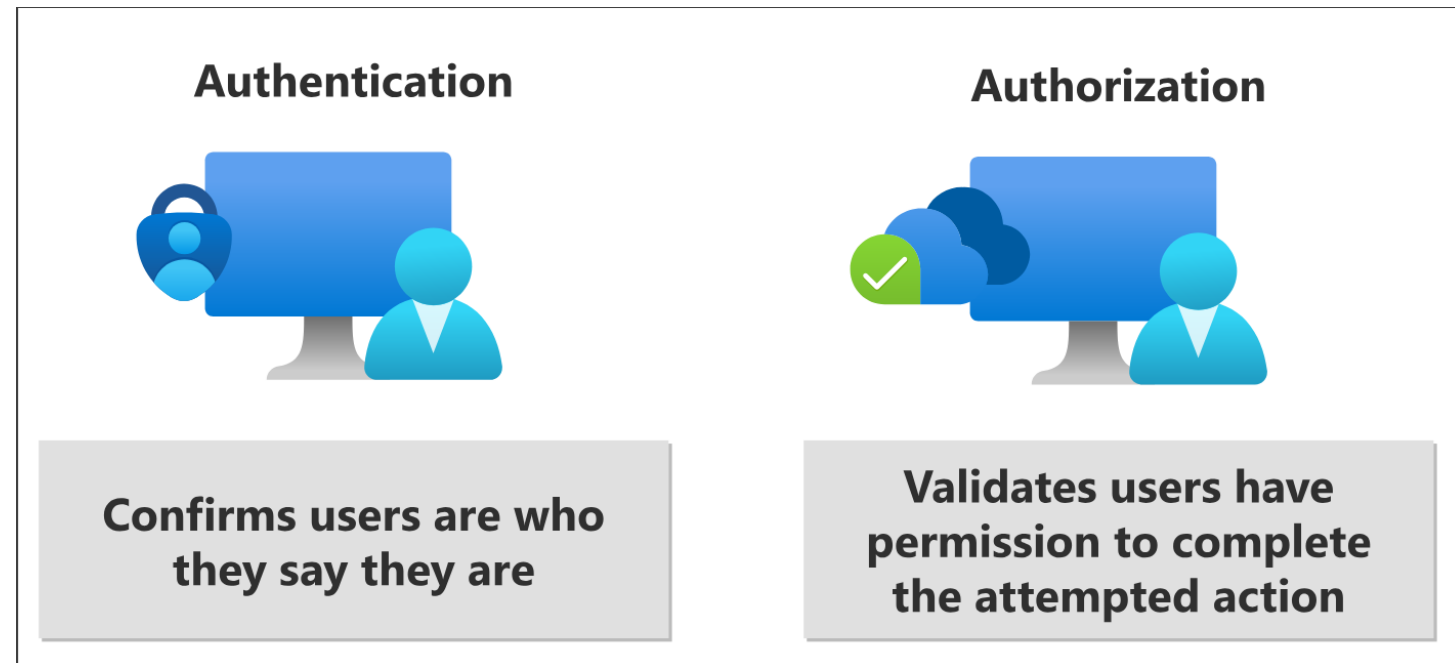
Authentication and authorization

Authentication

- Verification of the identity of the user/security principal
- Cryptographic, e.g., token signature

Authorization

- Verification of user/security principal permissions for the executed action
- E.g., role verification via claim in token or callback to IAM



<https://learn.microsoft.com/de-de/entra/fundamentals/identity-fundamental-concepts>

Protocols: OAuth2 and OIDC

OAuth2

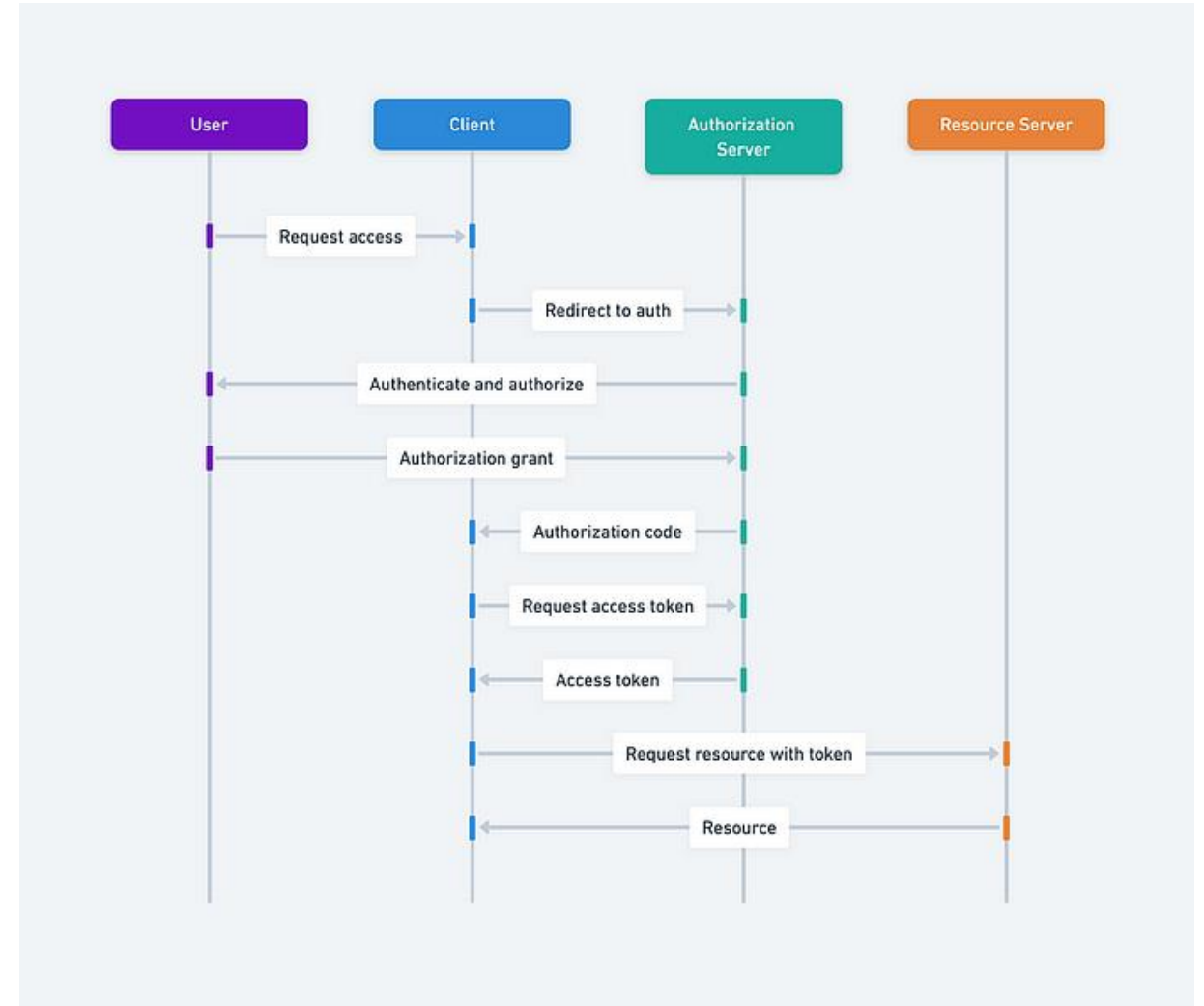
- Authorization standard (what are you allowed to do?)
- Supports different flows (Authcode flow on the right)

OpenID Connect (OIDC)

- Standard on top of OAuth2
- Extends the protocol for identification of clients (who are you?)

Key characteristics

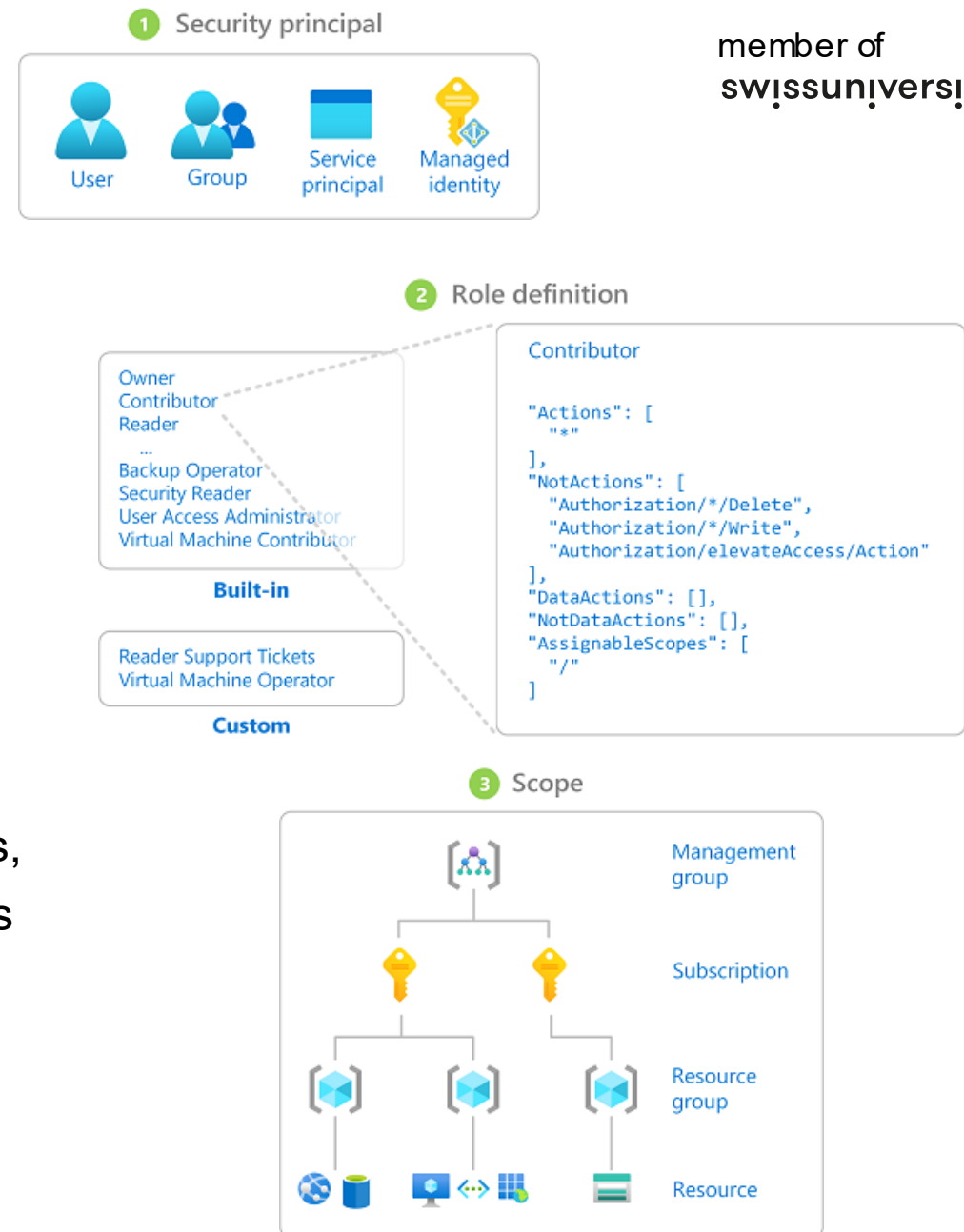
- Authentication/Authorization is done by a separate server
- The resource server (usually app server) trusts the authZ server
- Each request contains a “Bearer” token with authN/authZ information



<https://medium.com/@vino7tech/in-depth-explanation-of-oauth-2-0-9c318ca1d091>

RBAC = Role-Based Access Control – in Azure

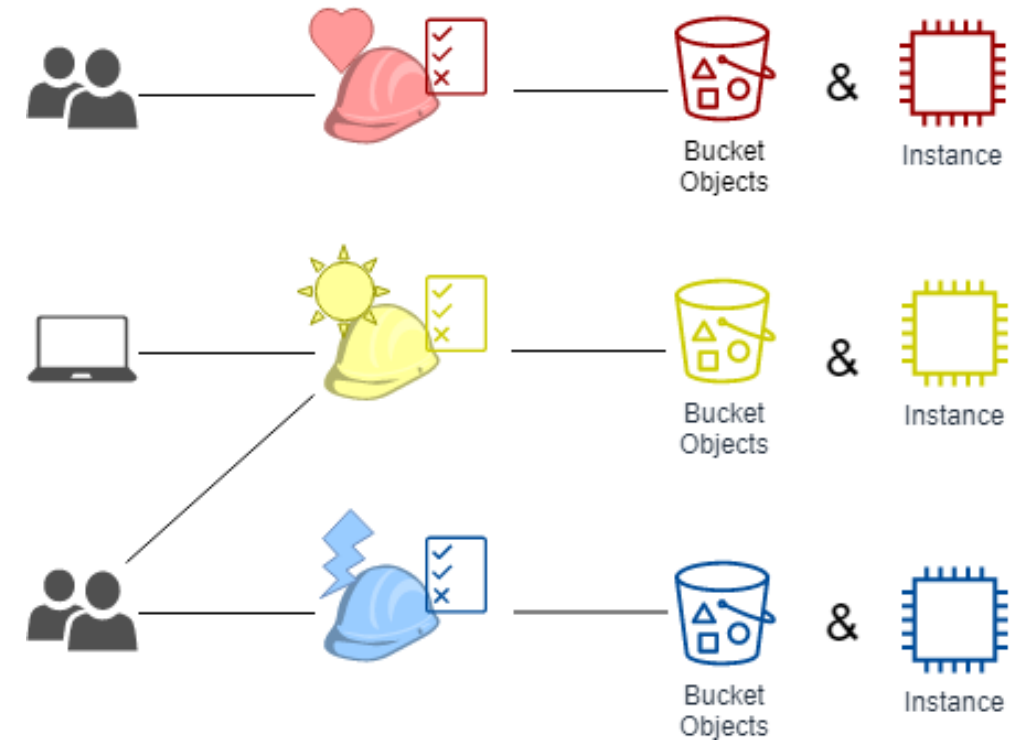
- Role-based authorization mechanism
- Roles specify access permissions, e.g., reading all storage accounts
- Roles are assigned to users, groups, or machine identities on a specific scope (e.g., a subscription)
- RBAC is usually static—no time-based permissions, no dynamic exclusions of resources, but extensions are available.



RBAC = Role-Based Access Control – in AWS

Role-based access:

- Roles are based on the organization.
- Roles are fixed; user affiliations are not.
- RBAC is static in relation to resources.
- Resources in the cloud can be volatile.



RBAC-Imposter:

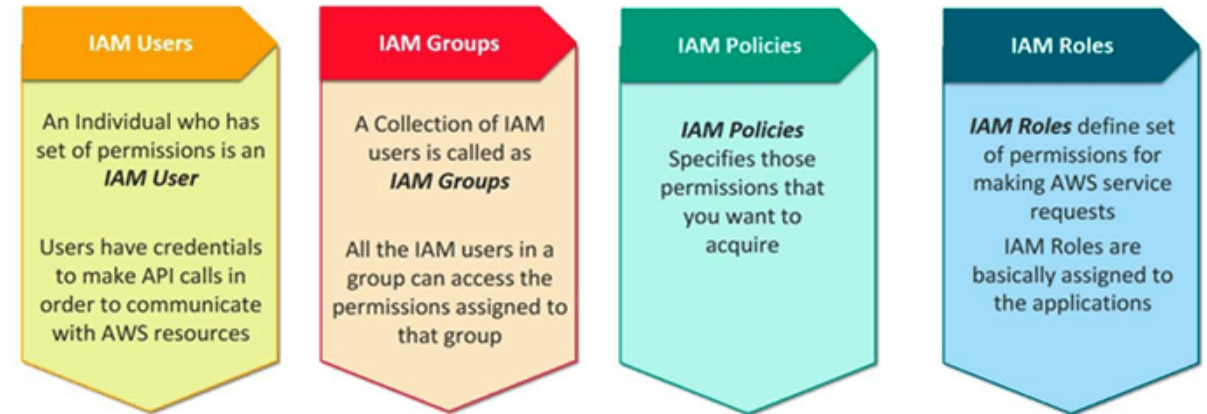
AWS Identity Access Management (IAM)

- Central AWS Service, caring about access to AWS resources
- IAM supports **Authentication** (Signed in) and **Authorization** (has permission) for any resources in AWS.
- Each AWS-Account consists of at least one IAM-Benutzer (root). This user should not be used for daily work (Best Practice).

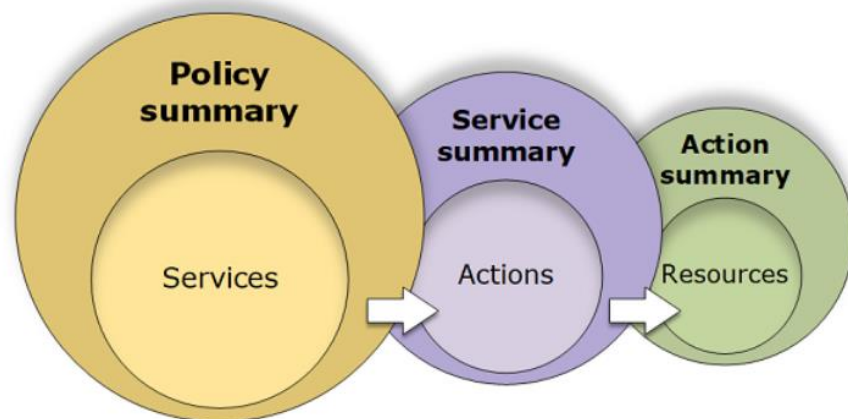


Components of IAM

- User: Personal, System, Application:
Aggregates several roles
- Group: Group of Users.
A User can be member of several groups
- Policies/Permissions: ABAC/RBAC-Rules, pre-defined or self defined
- Roles: Defined Set of Policies, pinned to user



IAM – Policies / Permissions



Example Policy for DB-Access

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Effect": "Allow",
    "Action": "dynamodb:*",
    "Resource": "arn:aws:dynamodb:us-east-2:123456789012:table/Books"
  }
}
```

- Access are granted via Policies/Permissions
- Per default: new Users have no Policy / Role attached
- Access are defined by ABAC/RBAC-Rules and have always the same layout:
 - Azure:
 - [dataA|a]ctions: Ressource / Action to be allowed
 - not[DataA|a]ctions: Ressource / Action to be forbidden
 - AWS:
 - Effect: allow or deny
 - Action: Action, matching the rule
 - Resource: Resource, matching the rule

RBAC in AWS via IAM Roles



IAM policy

Permissions are specified in an IAM policy:

A document formatted in JavaScript Object Notation (JSON)

It defines which resources and operations are allowed

Best practice – follow the principle of least privilege

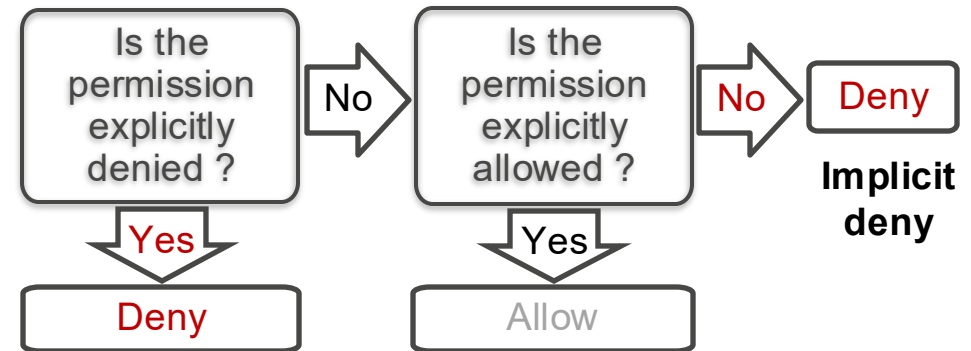
Two types of policies:

- Identity-based: Attach to an IAM principal
- Resource-based: Attach to an AWS resource

<https://policysim.aws.amazon.com/>



How IAM determines permissions at the time of request:



Consider this IAM policy, then answer the questions as they are presented.

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Effect": "Allow",
    "Action": [
      "iam:Get*",
      "iam:List*"
    ],
    "Resource": "*"
  }
}
```

1. Which AWS service does this policy grant you access to?
 - ANSWER: The IAM service.
2. Does it allow you to create an IAM user, group, policy, or role?
 - ANSWER: No. The access is limited to get and list requests. It effectively grants read-only permissions.
3. Go to <https://docs.aws.amazon.com/IAM/latest/UserGuide/> and in the left navigation expand Reference > Policy Reference > Actions, Resources, and Condition Keys. Choose Identity And Access Management. Scroll to the Actions Defined by Identity And Access Management list.

Name at least three specific actions that the iam:Get* action allows.
 - ANSWER: iam:Get* allows many specific actions, including GetGroup, GetPolicy, GetRole, and others.

Consider this IAM policy, then answer the questions as they are presented.

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": ["ec2:TerminateInstances"],
      "Resource": ["*"]
    },
    {
      "Effect": "Deny",
      "Action": ["ec2:TerminateInstances"],
      "Condition": {
        "NotIpAddress": {
          "aws:SourceIp": [
            "192.0.2.0/24",
            "203.0.113.0/24"
          ]
        }
      },
      "Resource": ["*"]
    }
  ]
}
```

- Does the policy allow you to terminate any EC2 instance at any time without conditions?
 - ANSWER: No. The first statement object allows it. However, the second statement object applies a condition.
- Are you allowed to make the terminate instance call from anywhere?
 - ANSWER: No. You can only make the request from one of the two IP address ranges that are specified in `aws:SourceIp`.
- Can you terminate instances if you make the call from a server that has an assigned IP address of 192.0.2.243?
 - ANSWER: Yes, because the 192.0.2.0/24 Classless Inter-Domain Routing (CIDR) IP address range includes IP addresses 192.0.2.0 through 192.0.2.255. A resource like the [CIDR to IP Range](#) tool can be used to calculate the range of a CIDR block.

Consider this IAM policy, then answer the questions as they are presented.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Condition": {
      "StringEquals": {
        "ec2:InstanceType": [
          "t2.micro",
          "t2.small"
        ]
      }
    },
    "Resource": "*",
    "Action": [
      "ec2:RunInstances",
      "ec2:StartInstances"
    ],
    "Effect": "Deny"
  }]
}
```

1. What actions does the policy allow?
 - ANSWER: It does not allow you to do anything (the effect is to Deny).
2. Say that the policy included an additional statement object, like this example:

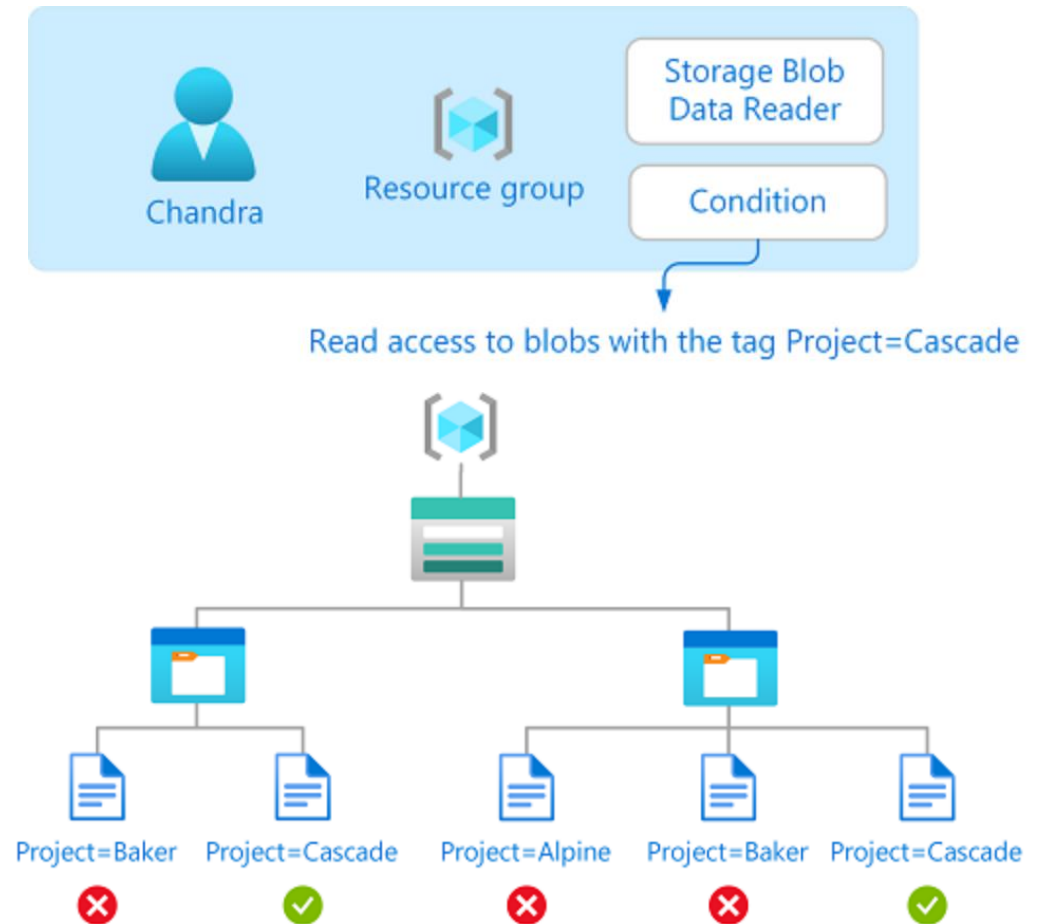
```
{
  "Effect": "Allow",
  "Action": "ec2:*"
}
```

How would the policy restrict the access granted to you by this additional statement?

 - ANSWER: You would have full Amazon EC2 service access. However you would only be allowed to launch or start EC2 instances of instance except type t2.micro or t2.small.
3. If the policy included both the statement on the left and the statement in question 2, could you terminate an m3.xlarge instance that existed in the account?
 - ANSWER: Yes.

ABAC = Attribute-Based Access Control - in Azure

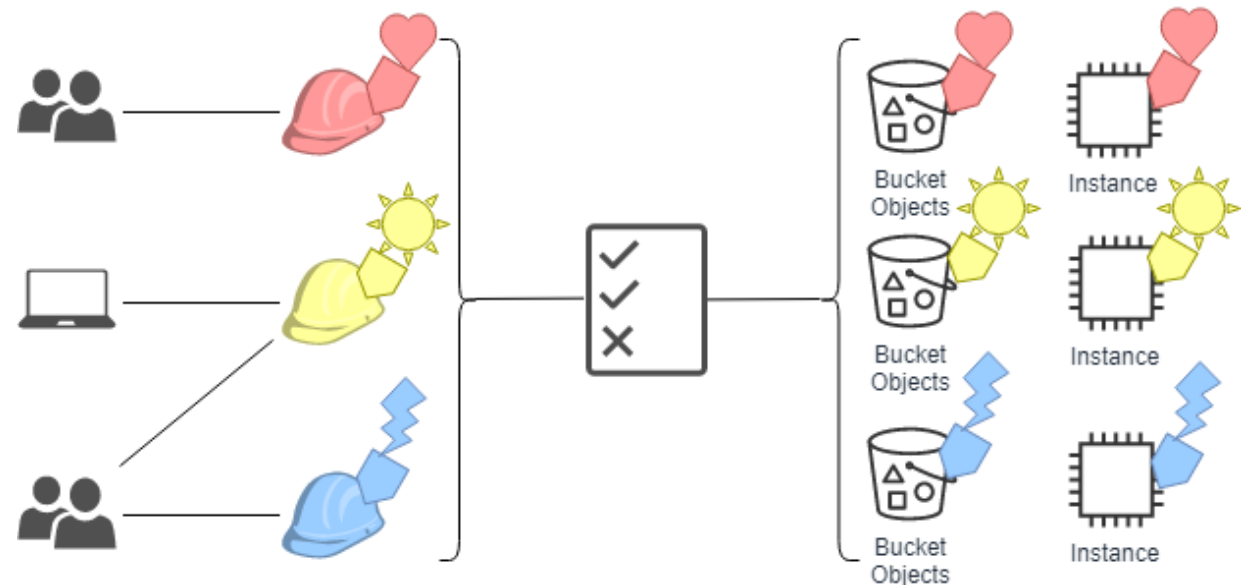
- More granular permission management compared to RBAC (however, Azure ABAC is based on Azure RBAC)
- Permissions are dynamically controlled using attributes
- Effective implementation: Azure RBAC role assignments take effect based on a condition depending on the resource
- Available attributes are context-specific



ABAC = Attribute-Based Access Control - in AWS

Mapping roles to attributes:

- Roles are based on the organization
- Roles are fixed; user affiliations are not
- Resources mark affiliation to roles via metadata (tags)



Cloud services identities

For Zero Trust all services need identities

- Azure provides (user) managed identities
- AWS IAM Service Role

These identities are controlled by the cloud customer. Allows for fine control over policies, access scope etc.

These identities allow for password less authentication and authorization.

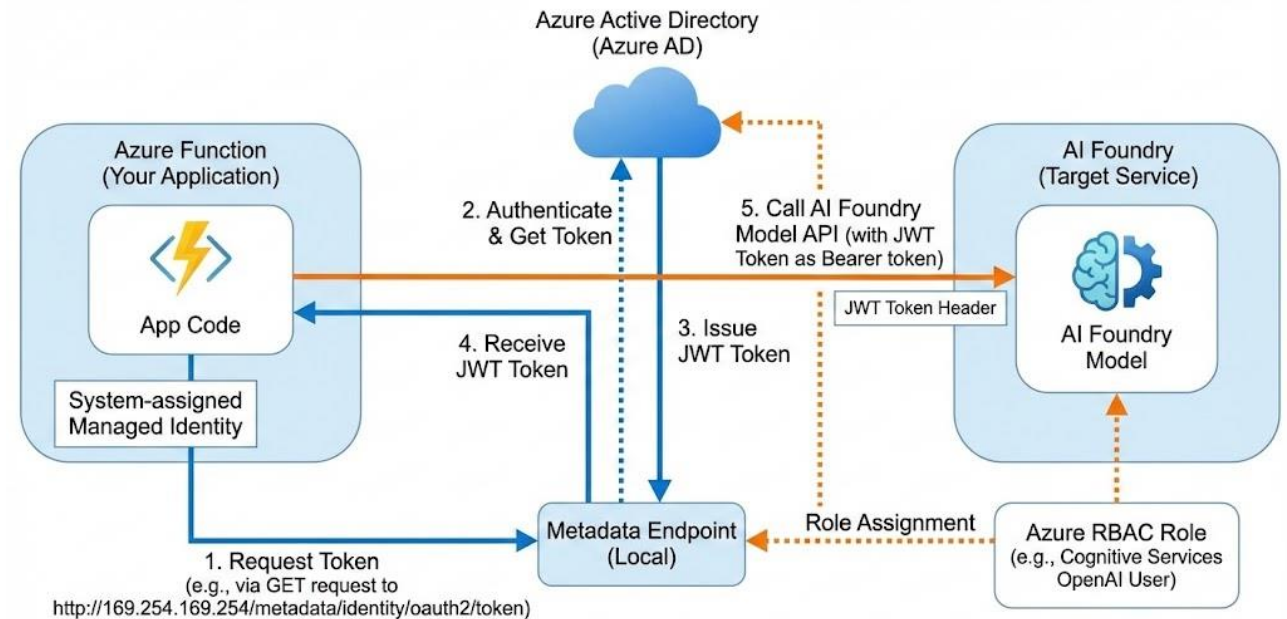


Diagram: Azure Managed Identity & Passwordless Authentication Flow to AI Foundry.

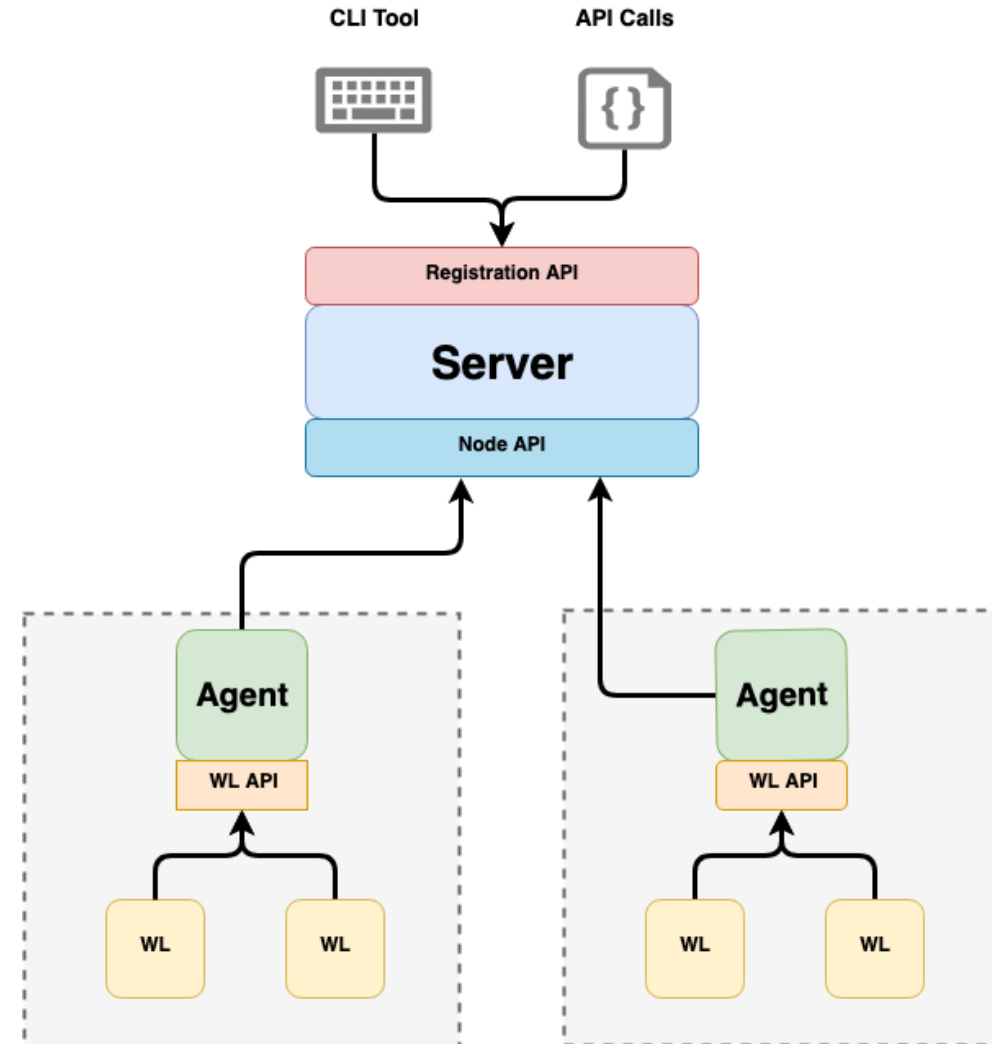
Generated through Nano Banana Pro

Cloud agnostic identities

SPIFFE (Secure Production Identity Framework for Everyone) is an open source standard to identify software systems across heterogeneous environments.

SPIRE (SPIFFE Runtime Environment) is the reference implementation.

Workloads (WL) receive a token or certificate from the Agent after being verified (i.e. checksums). Workloads may authenticate and authorize based on these tokens or certificates. E.g. app to Postgres communication.



Application security

Application security – OWASP Top 10

- OWASP = Open Worldwide Application Security Project
- Non-profit organization dedicated to improving application security
- Top 10 = Top risks for applications
- Rank 1 Broken Access Control – Example: Application uses AuthN & AuthZ, but token signatures are not checked

2021

A01:2021-Broken Access Control

A02:2021-Cryptographic Failures

A03:2021-Injection

A04:2021-Insecure Design

A05:2021-Security Misconfiguration

A06:2021-Vulnerable and Outdated Components

A07:2021-Identification and Authentication Failures

A08:2021-Software and Data Integrity Failures

A09:2021-Security Logging and Monitoring Failures*

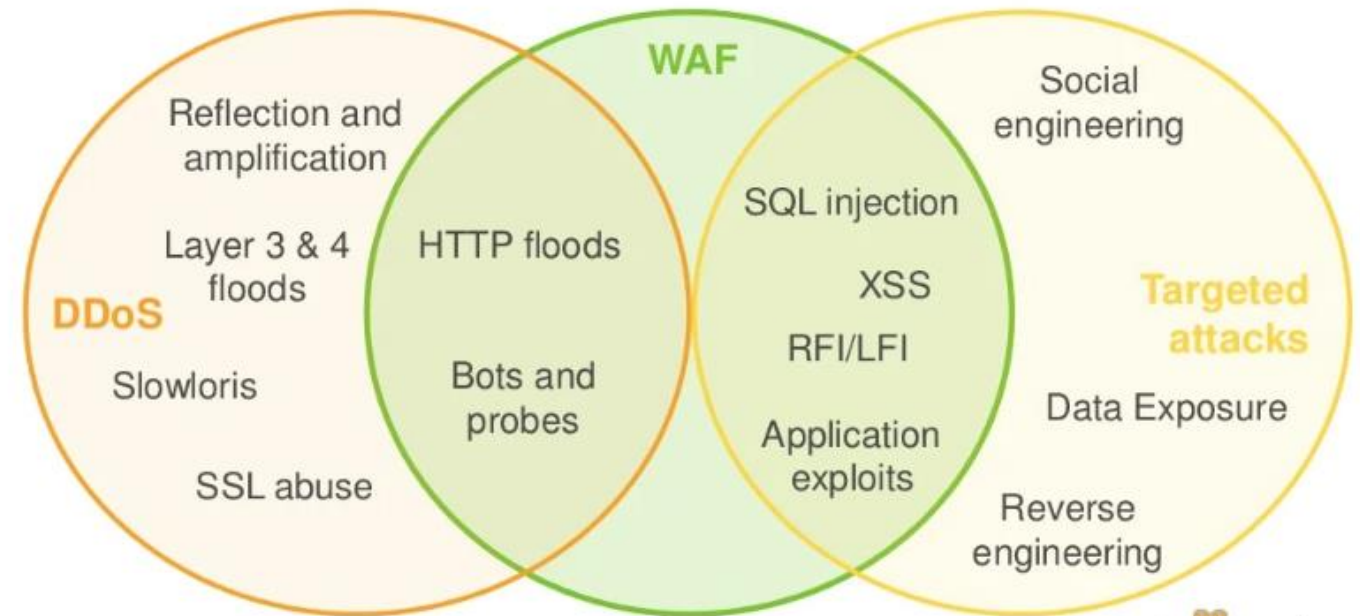
A10:2021-Server-Side Request Forgery (SSRF)*

<https://owasp.org/www-project-top-ten/>

Web Application Firewall (WAF)

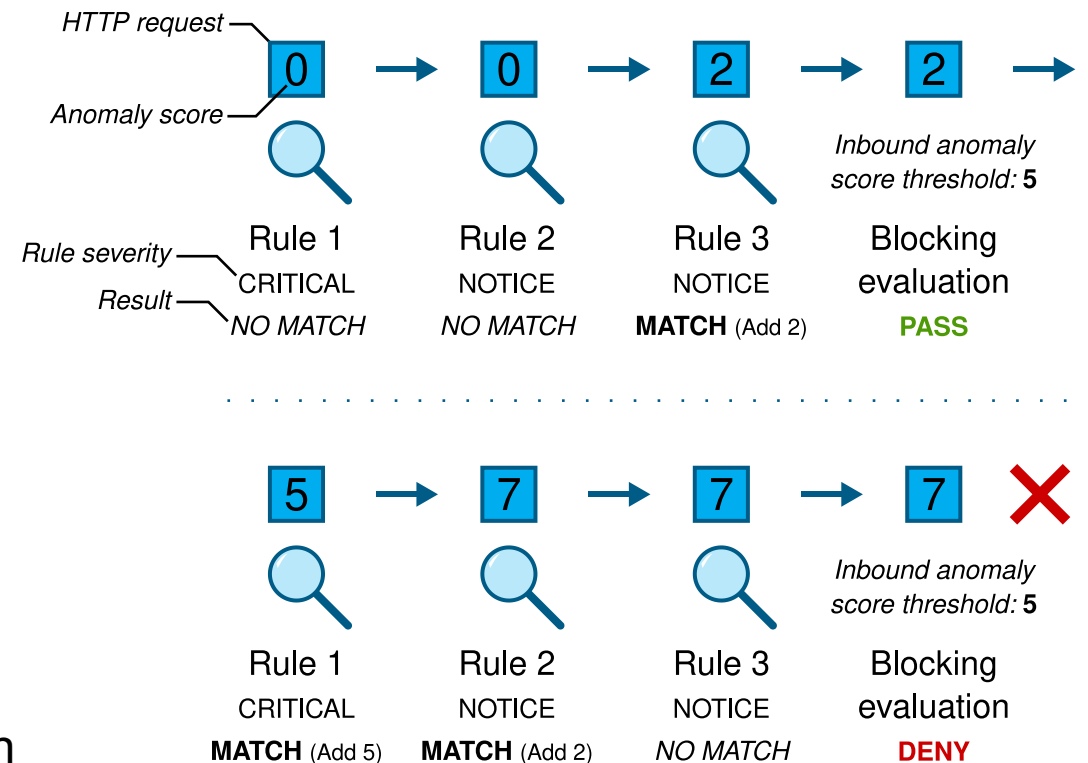
- Own component or service upstream of applications
- HTTP requests are checked for common attacks (e.g., XSS)
- Additional security module for application-level attacks
- Requires coordination between developers and WAF operations (false positives)

WAF Positioning in the Spectrum of Attacks



Web Application Firewall (WAF) – Core Rule Set (CRS)

- OWASP CRS is a collection of WAF rules, including for OWASP Top 10.
- Compatible with Modsecurity (WAF implementation).
- HTTP requests are evaluated by rules. If a rule applies, the anomaly score increases.
- Anomaly score above a threshold -> request is blocked.
- Paranoia level determines the rules used based on their sensitivity.



Frameworks

Security and compliance frameworks

- Organizations must be able to meet various regulatory standards, e.g., PCI DSS.
- Applying standards via autonomous teams is challenging from an organizational perspective -> automation using cloud services.
- The cloud's API-first approach helps to validate configurations uniformly and automatically.

▼ Regulatory Compliance built-ins

▼ Azure built-ins

- Australian Government ISM PROTECTED
- Canada Federal PBMM
- CIS Microsoft Azure Foundations Benchmark 1.1.0
- CIS Microsoft Azure Foundations Benchmark 1.3.0
- CIS Microsoft Azure Foundations Benchmark 1.4.0
- CIS Microsoft Azure Foundations Benchmark 2.0.0
- CMMC Level 3
- FedRAMP High
- FedRAMP Moderate
- HIPAA HITRUST 9.2
- IRS 1075 September 2016
- ISO 27001:2013
- Microsoft cloud security benchmark
- Microsoft Cloud for Sovereignty Confidential
- Microsoft Cloud for Sovereignty Global
- NIST SP 800-53 Rev. 4
- NIST SP 800-53 Rev. 5
- NIST SP 800-171 R2
- NL BIO Cloud Theme
- PCI DSS 3.2.1
- PCI DSS 4.0

Security and compliance frameworks

- Each cloud (resource) has specific best practices for configuration (e.g., disabling public access).
- Similar to hardening for operating systems.
- NIST & CIS Frameworks
- Cloud provider-specific, such as Azure Security Benchmark or AWS Control Tower Detective Guardrails.

AzPolicyAdvertizer

last sync: 2025-Oct-17 17:23:17 UTC

Configure Function apps to disable public network access

Azure BuiltIn Policy definition

Source	Azure Portal
Display name	Configure Function apps to disable public network access
Id	cd794351-e536-40f4-9750-503a463d8cad COPY ID COPY RESOURCEID
Version	1.2.0 Details on versioning
Versioning	Versions supported for Versioning: 2 1.2.0 1.1.0 Built-in Versioning [Preview]
Category	App Service Microsoft Learn
Description	Disable public network access for your Function apps so that it is not a
Cloud environments	AzureCloud = true AzureUSGovernment = true AzureChinaCloud = unknown
Available in AzUSGov	The Policy is available in AzureUSGovernment cloud. Version: '1.*.*'
Mode	Indexed
Type	BuiltIn
Preview	False
Deprecated	False
Effect	Default Modify Allowed Modify, Disabled

Security and compliance frameworks – Azure Policy

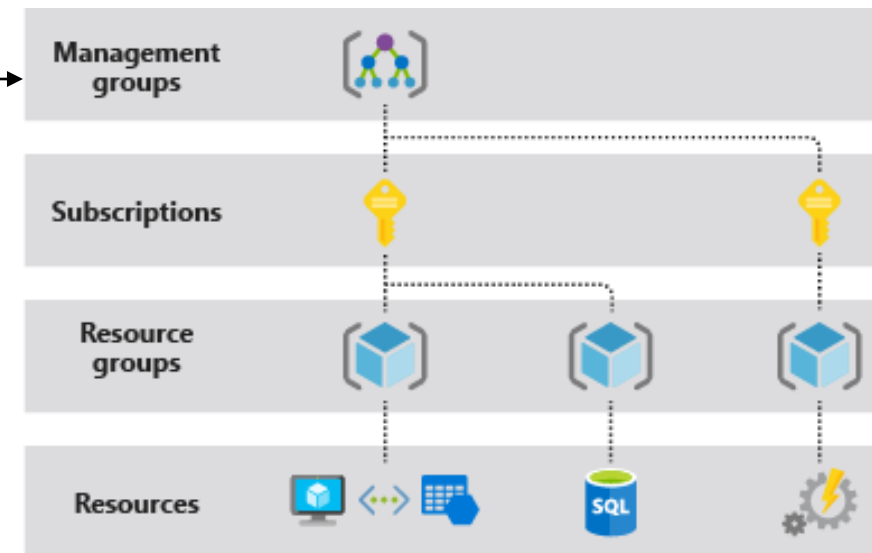
- Engine for monitoring and enforcing policies across the organization
- Initiative: Collection of policies (e.g., Azure Security Benchmark)
- Policy: A specific policy (e.g., disable public access for storage accounts)
- Scope: Location in the Azure resource hierarchy where the policy or initiative is applied (e.g., resource group)
- (Policy) Assignment: Assignment of a policy or initiative to a scope
- Effect: Monitoring, enforcement (or similar) of the policy/initiative

Security and compliance frameworks – Azure Policy

```
{
  "properties": {
    "displayName": "Allowed locations",
    "description": "This policy enables you to restrict the locations your organization can specify",
    "mode": "Indexed",
    "metadata": {
      "version": "1.0.0",
      "category": "Locations"
    },
    "parameters": {
      "allowedLocations": {
        "type": "array",
        "metadata": {
          "description": "The list of locations that can be specified when deploying resources",
          "strongType": "location",
          "displayName": "Allowed locations"
        },
        "defaultValue": [
          "westus2"
        ]
      }
    },
    "policyRule": {
      "if": {
        "not": {
          "field": "location",
          "in": "[parameters('allowedLocations')]"
        }
      },
      "then": {
        "effect": "deny"
      }
    }
  }
}
```

Assign to Scope

Parameter
allowedLocations
= switzerlandnorth

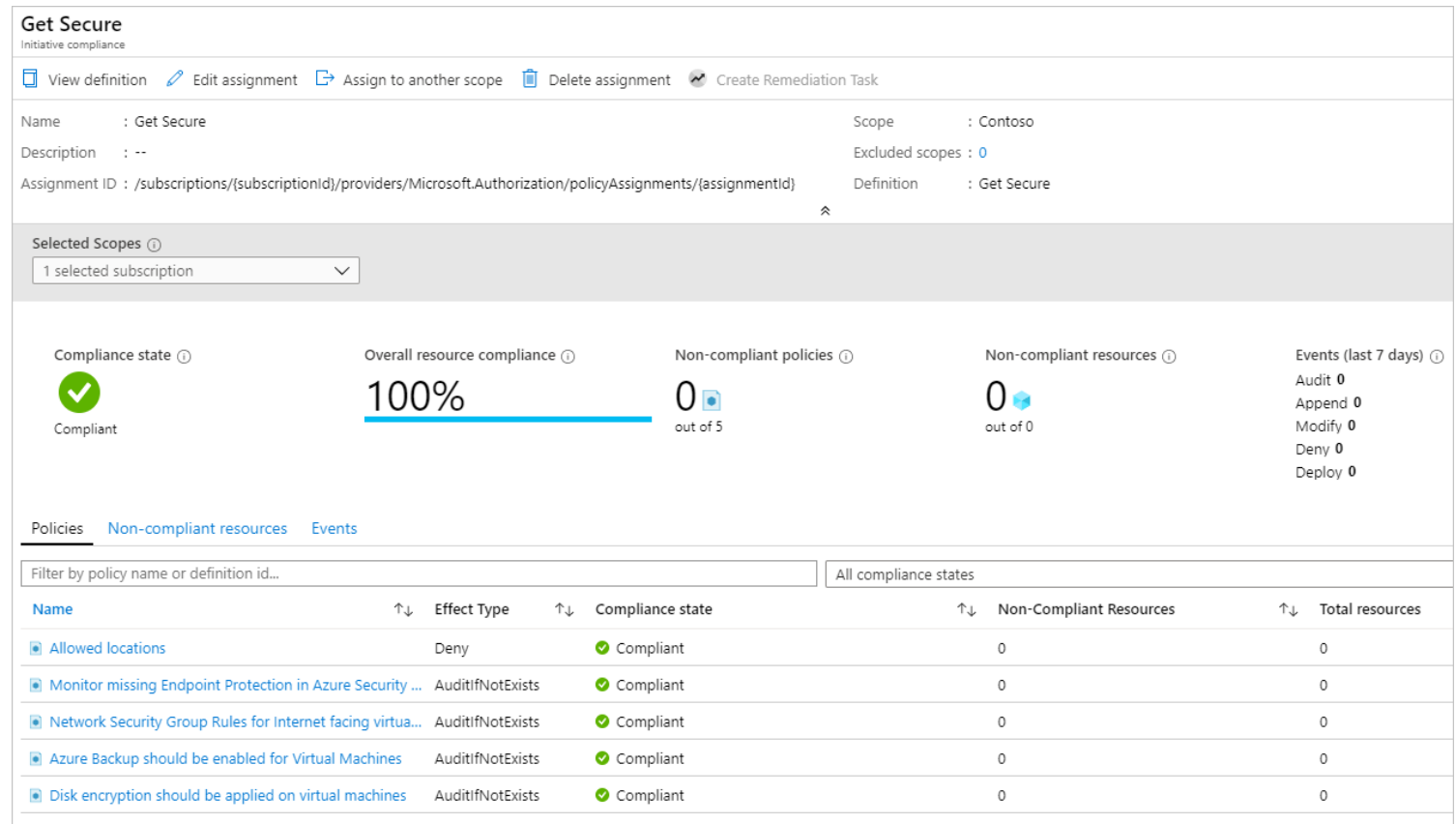


Result: Resources are only allowed to be deployed to Switzerland North.

<https://learn.microsoft.com/en-us/azure/azure-resource-manager/management/overview> und <https://learn.microsoft.com/en-us/azure/governance/policy/concepts/definition-structure-basics>

Security and compliance frameworks – Azure Policy

- Continuous monitoring of policies/initiatives
- Visibility of the current status of the environment via dashboard
- Optimized auditing and alerting in case of misconfiguration



<https://learn.microsoft.com/en-us/azure/governance/policy/tutorials/create-and-manage>

Demo, AWS SCPs

- https://gitlab.fhnw.ch/cloud/archive/23fs-automatisiertes-accounting-auf-aws/automated-accounting/-/blob/main/terraform/policies.auto.tfvars?ref_type=heads

Best practices

- Use of MFA (or external identity provider with MFA)
- Regular rotation of keys (or via managed identities)
- Root users should not be used as regular users (i.e., do not use CLI keys either).
- Implement least-privilege permissions based on ABAC
- Regular review of resources
- Account structure architecture
- IaC (linting, scanning/shift-left)



Excursion

Not relevant for the
exam

Excursion: How the cloud is used in companies

Reasons to use the cloud:

- Access to more and different infrastructure
- Purely API based management of resources
- Reduced operational effort
- Because it is trending (sad but true)

Challenges:

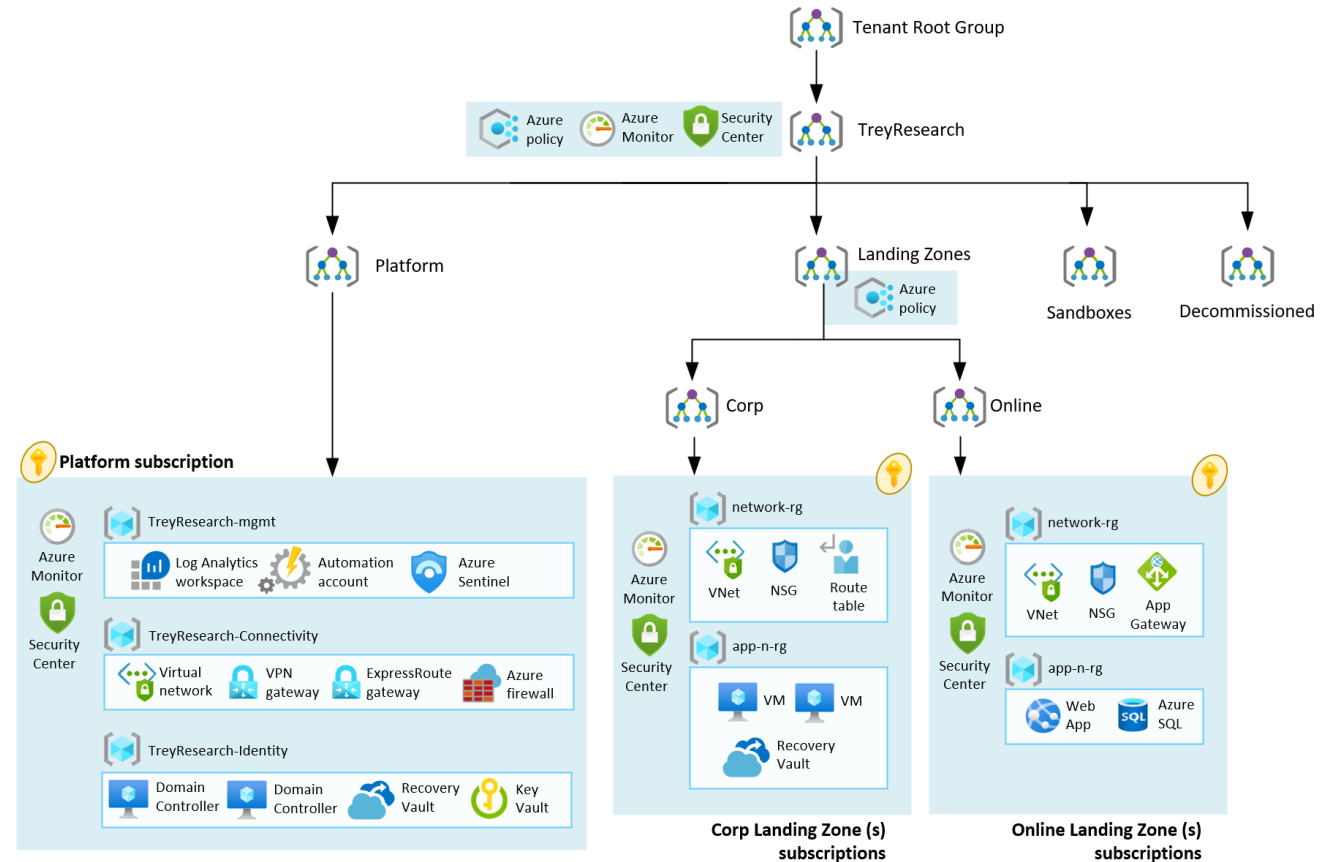
- Lots of concepts, when to use which one
- Acceleration of teams
- Organizational development

Not relevant for the exam

Excursion: How the cloud is used in companies

Organization of the cloud for a whole organization

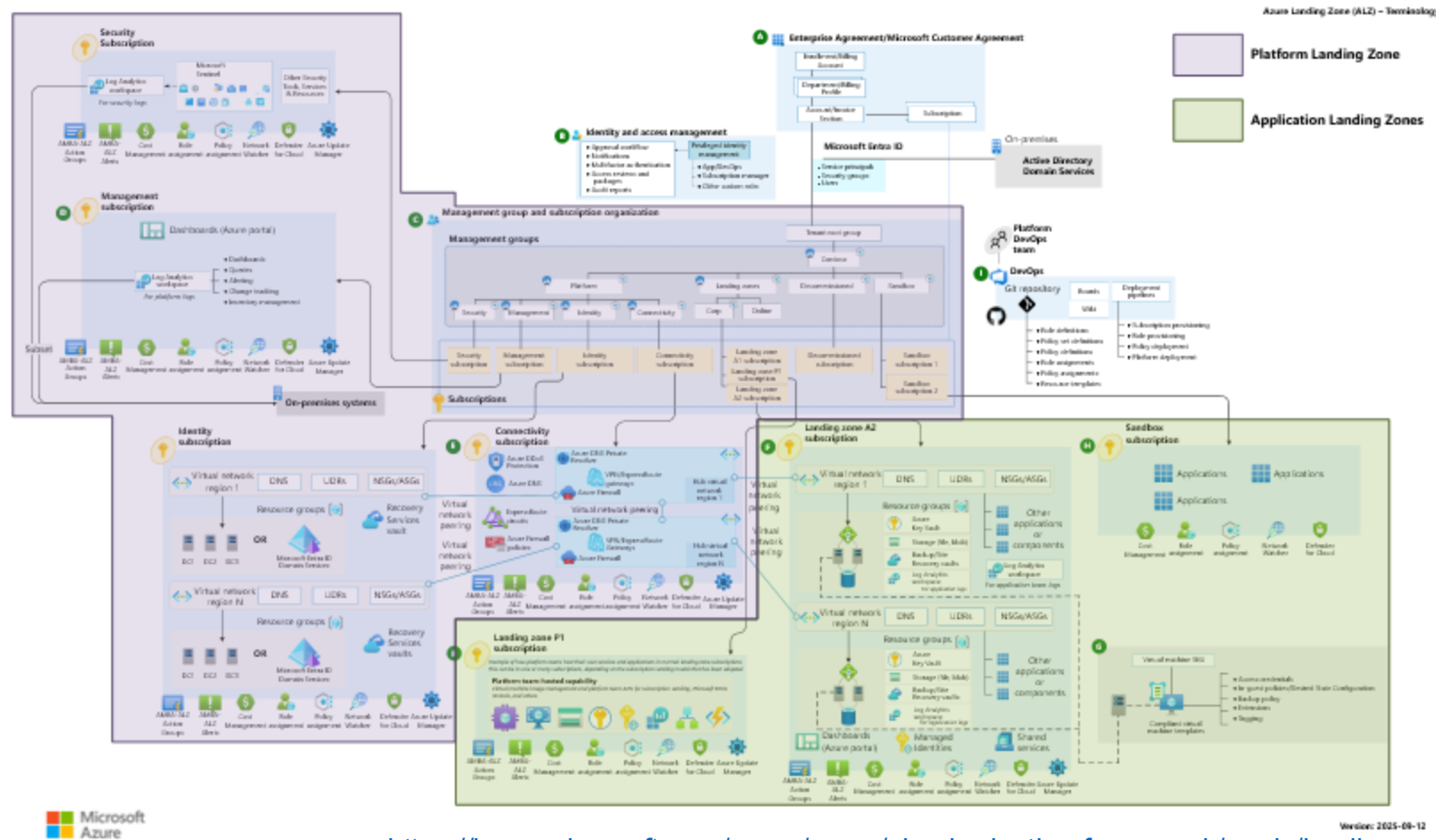
- Reference architecture: Enterprise Scale
- Different expansion stages available (foundation, network with hub spoke or wan, for small enterprises – see image)
- Design areas
 - The structure of the cloud (where to find what)
 - Who can access what
 - Centralized services (i.e. DNS or on-prem connectivity)
 - Predefined environments «landing zones»
 - Responsibilities for app teams
 - Security rules



Excursion: How the cloud is used in companies

Not relevant for the exam

Platform and Application Landing Zones



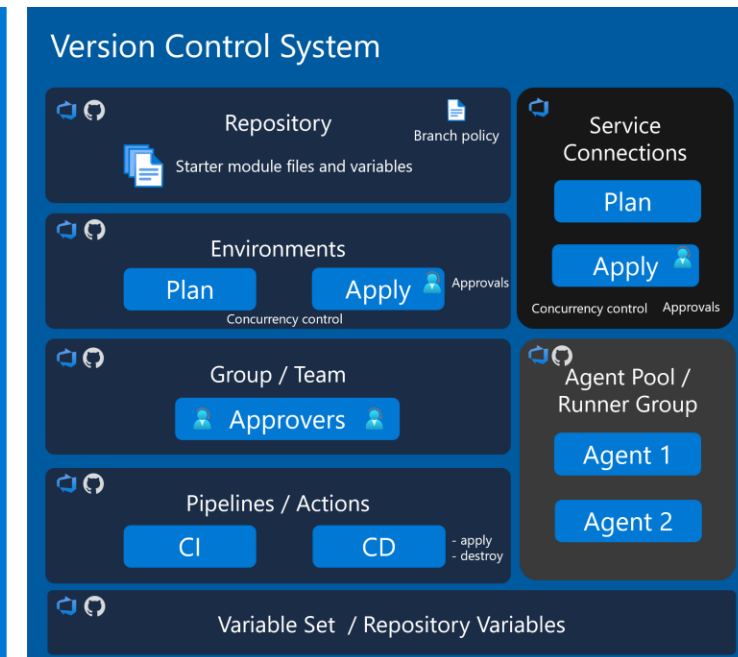
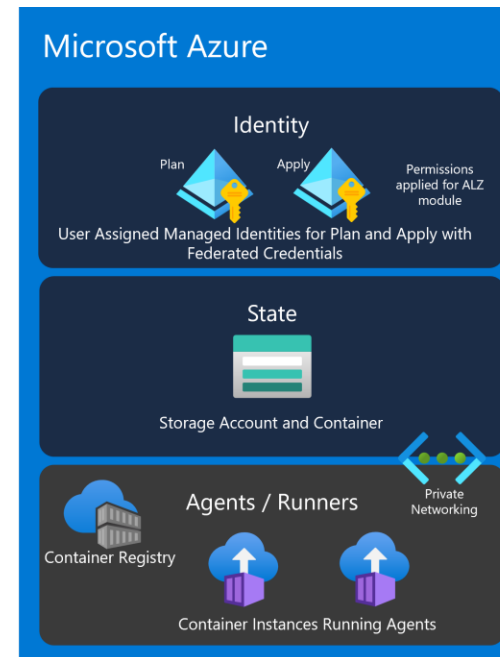
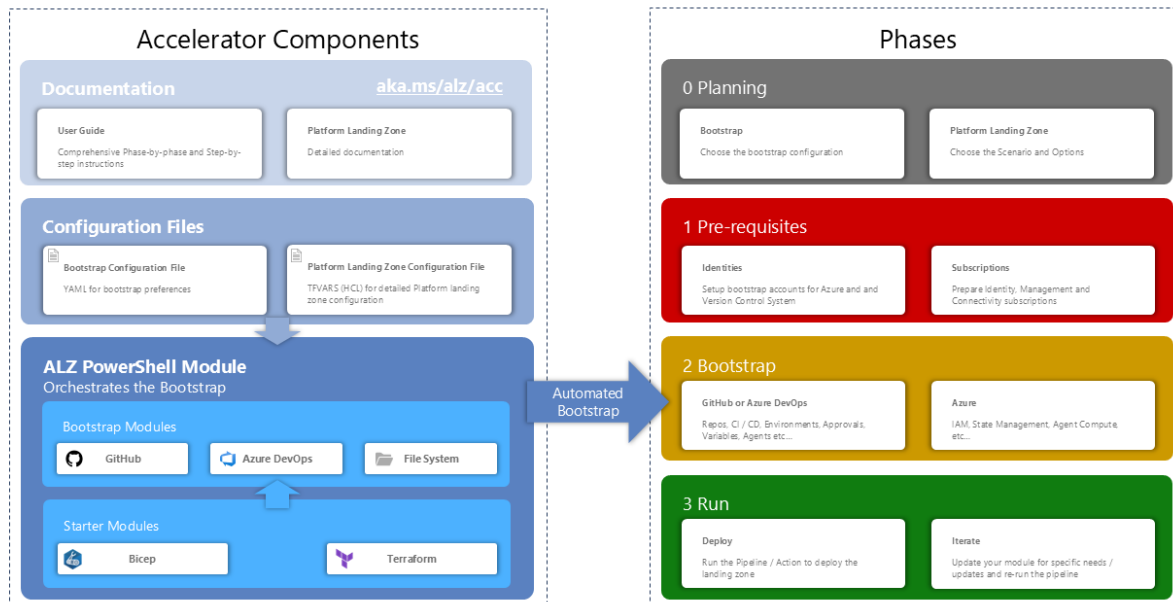
<https://learn.microsoft.com/en-us/azure/cloud-adoption-framework/ready/landing-zone/>

Not relevant for the
exam

Excursion: How the cloud is used in companies

Bootstrapping of empty cloud environments via IaC Accelerators

Azure Landing Zones IaC Accelerator

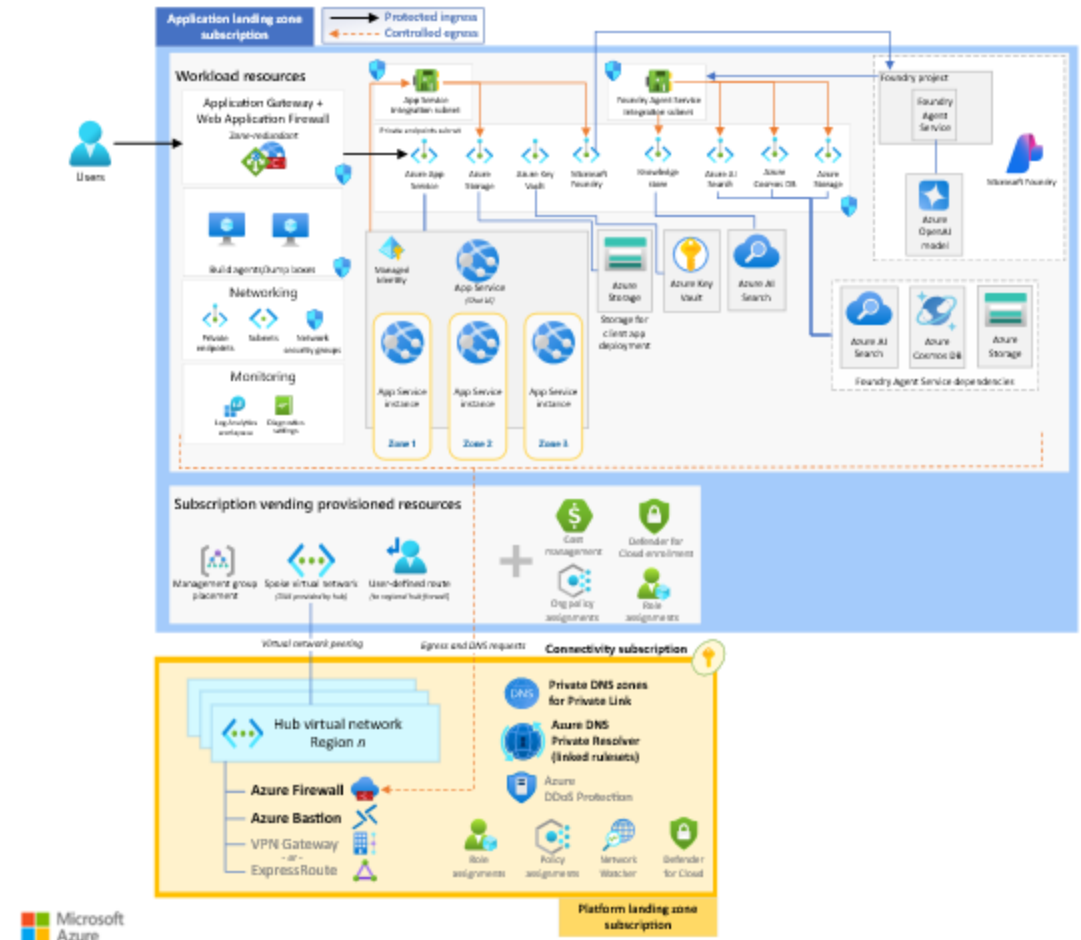
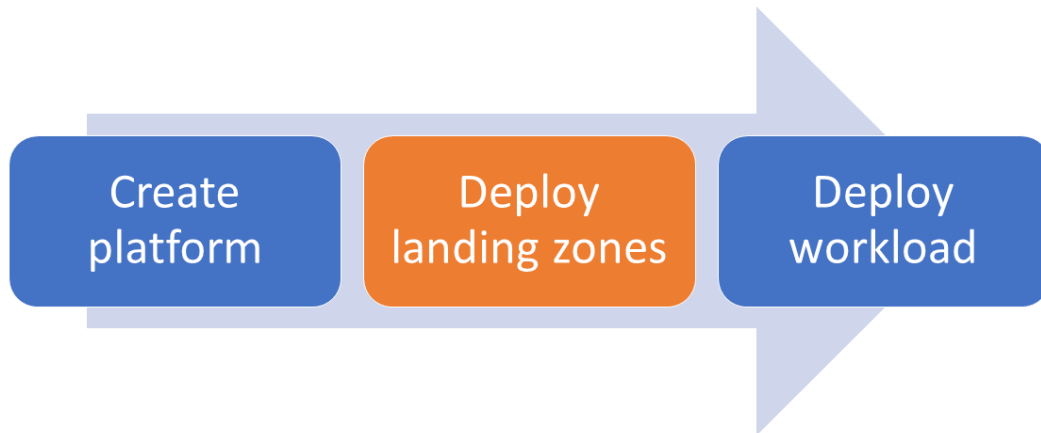


<https://azure.github.io/Azure-Landing-Zones/accelerator/>

Excursion: How the cloud is used in companies

Not relevant for the exam

Onboarding of new apps / teams through subscription vending.



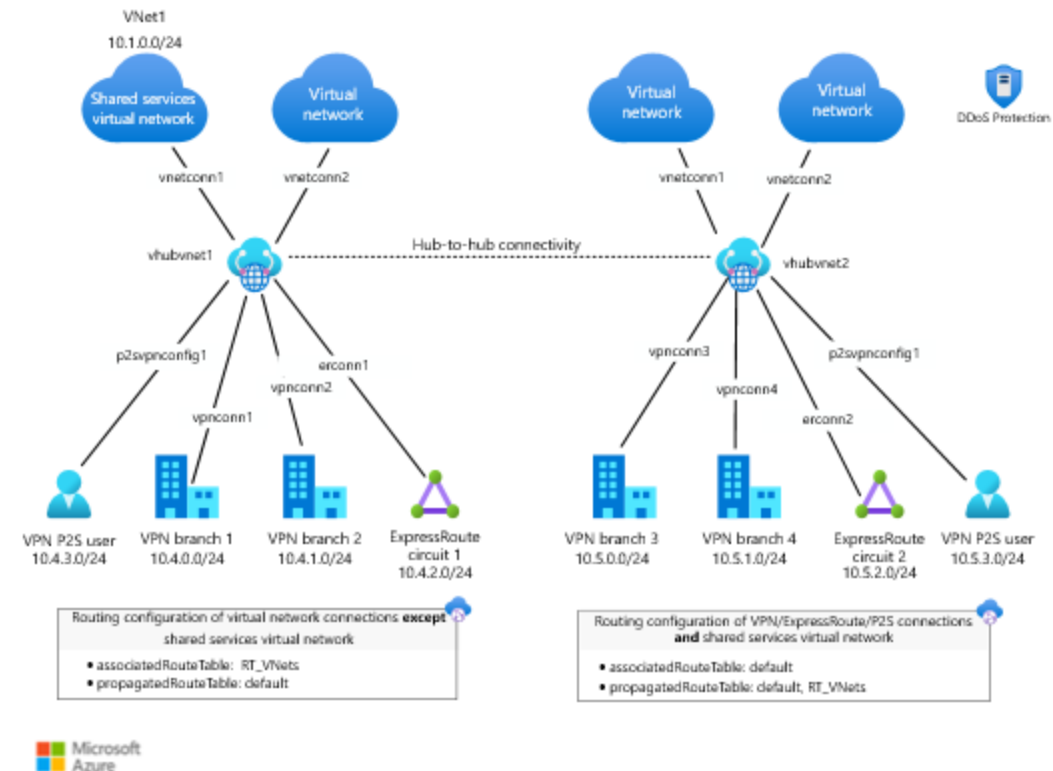
<https://learn.microsoft.com/en-us/azure/architecture/ai-ml/architecture/baseline-azure-ai-foundry-landing-zone>

Not relevant for the
exam

Excursion: How the cloud is used in companies

Providing on-premises connectivity and integration

- Centrally implemented, used by all apps
- Knows different technologies: VNET based or Virtual WAN based
- Needs a dedicated team depending on the organization size



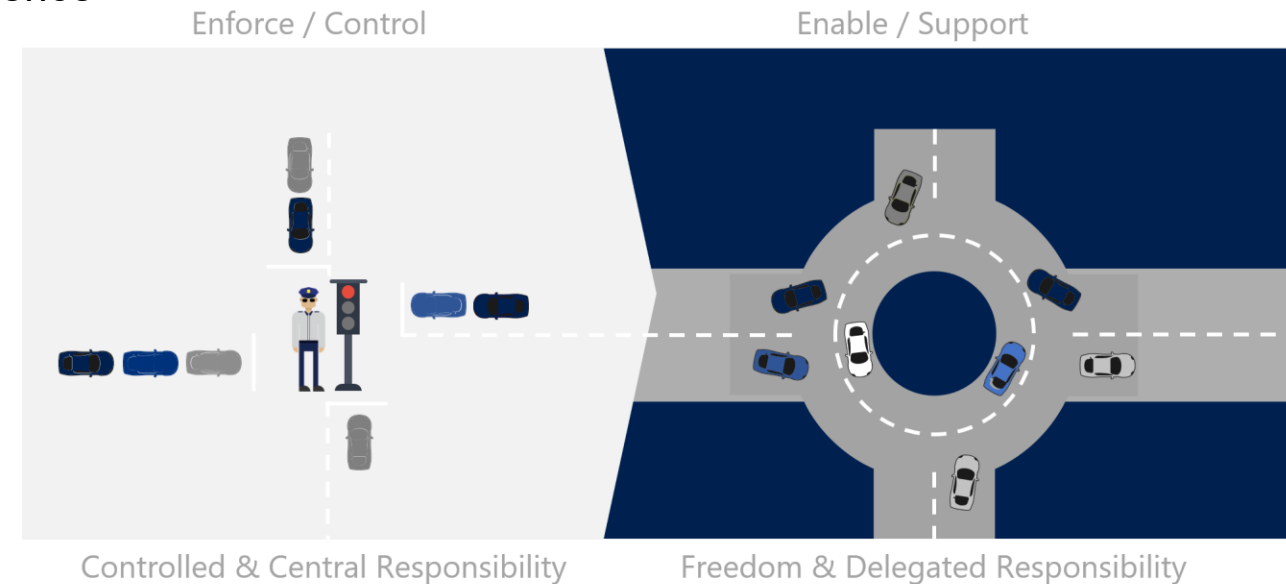
<https://learn.microsoft.com/en-us/azure/architecture/networking/architecture/hub-spoke-virtual-wan-architecture>

Not relevant for the
exam

Excursion: How the cloud is used in companies

Organizational impact of Clouds

- Organizations usually setup a «Cloud center of excellence» (CCoE)
- Cloud know-how and operations is inside that team
- The CCoE provides services into the organization
 - Operations of the cloud
 - Onboarding of new apps or environments
 - Consulting for app teams
 - Automation of the cloud platform
 - Central interface for on-prem integrations



<https://learn.microsoft.com/en-us/azure/cloud-adoption-framework/organize/cloud-center-of-excellence>

Homework

- Review the material from this lesson.
- Complete [Assignment 13](#).
- Deepen your understanding of security concepts and services with the learnpaths:
 - [Secure your cloud data \(4 Module\)](#)
 - [Manage security operations in Azure \(4 Module\)](#)

